

Rapport SCA Wazuh

Projet CYNA - Security Configuration Assessment

Évaluation de conformité et de durcissement des machines supervisées

Contexte	Projet Fil Rouge CYNA - Supervision et sécurité
Outil	Wazuh - Security Configuration Assessment (SCA)
Référentiels	CIS Microsoft Windows Server 2022 Benchmark v2.0.0 / CIS Debian Linux 13 Benchmark
Machines auditées	DC01, DC02, Web, Web2, HAProxy-DMZ, Syslog-GVA, Veeam

1. Objectif du rapport

Dans le cadre de la validation de la sécurité de l'infrastructure CYNA, un audit SCA, pour Security Configuration Assessment, a été réalisé depuis la console Wazuh. L'objectif de cet audit est d'évaluer le niveau de conformité des machines supervisées par rapport aux recommandations de sécurité issues des benchmarks CIS.

Cette analyse permet d'identifier les écarts de configuration, les points de durcissement à appliquer et les priorités d'amélioration sur les systèmes Windows et Linux supervisés.

2. Périmètre analysé

Les machines analysées sont les principaux serveurs supervisés par Wazuh : les contrôleurs de domaine DC01 et DC02, les serveurs Web et Web2 placés en DMZ, le serveur HAProxy-DMZ, le serveur Syslog-GVA ainsi que le serveur Veeam. Ces machines représentent des composants critiques de l'infrastructure, car elles assurent l'authentification, la publication de services, la centralisation des journaux, la supervision et la sauvegarde.

3. Synthèse des résultats SCA

Machine	Politique SCA appliquée	Réussis	Échoués	N/A	Score	Niveau
DC01	CIS Microsoft Windows Server 2022 Benchmark v2.0.0	90	269	0	25 %	Faible
DC02	CIS Microsoft Windows Server 2022 Benchmark v2.0.0	90	269	0	25 %	Faible
Web	CIS Debian Linux 13 Benchmark	75	103	29	42 %	Faible
Web2	CIS Debian Linux 13 Benchmark	75	103	29	42 %	Faible
HAProxy-DMZ	CIS Debian Linux 13 Benchmark	76	102	29	42 %	Faible
Syslog-GVA	CIS Debian Linux 13 Benchmark	75	99	33	43 %	Faible
Veeam	CIS Microsoft Windows Server 2022 Benchmark v2.0.0	87	272	0	24 %	Faible

Constat principal : aucun serveur n'atteint l'objectif initial de conformité de 70 %. Les serveurs Linux se situent entre 42 % et 43 %, tandis que les serveurs Windows se situent entre 24 % et 25 %.

4. Analyse des résultats

Les résultats montrent que l'ensemble des machines supervisées présente un niveau de conformité encore perfectible. Les serveurs Linux obtiennent des scores compris entre 42 % et 43 %, tandis que les serveurs Windows obtiennent des scores compris entre 24 % et 25 %. Aucun serveur n'atteint pour le moment l'objectif initial de 70 % défini dans le plan de tests.

Sur les serveurs Windows, notamment DC01, DC02 et Veeam, les principaux écarts concernent les politiques de mot de passe, les paramètres de verrouillage de compte, l'historique des mots de passe et certains paramètres de sécurité recommandés par le benchmark CIS Microsoft Windows Server 2022. Ces écarts sont importants car les contrôleurs de domaine assurent l'authentification centrale de l'environnement, tandis que Veeam représente un serveur critique pour la sauvegarde et la reprise d'activité.

Sur les serveurs Linux, notamment Web, Web2, HAProxy-DMZ et Syslog-GVA, les écarts concernent principalement le durcissement système, les options de montage des partitions, la séparation des partitions sensibles, la configuration de certains services et les paramètres recommandés par le benchmark CIS Debian Linux 13. Ces résultats montrent que les machines fonctionnent correctement, mais qu'elles nécessitent encore des actions de durcissement pour améliorer leur posture de sécurité.

Les résultats SCA ne signifient pas nécessairement qu'une vulnérabilité critique est directement exploitable. Ils indiquent plutôt des écarts de configuration par rapport aux bonnes pratiques de sécurité. Ces écarts doivent être corrigés progressivement afin de renforcer la sécurité globale de l'infrastructure CYNA.

5. Actions correctives prioritaires

Priorité	Action corrective	Machines concernées
Haute	Renforcer les politiques de mot de passe et l'historique des mots de passe.	DC01, DC02, Veeam
Haute	Mettre en place ou ajuster les règles de verrouillage de compte.	DC01, DC02, Veeam
Haute	Restreindre les accès SSH au VLAN Management uniquement.	Web, Web2, HAProxy-DMZ, Syslog-GVA
Moyenne	Vérifier les permissions des fichiers sensibles et les services actifs.	Serveurs Linux
Moyenne	Durcir les options de montage des partitions Linux et séparer les partitions sensibles lorsque cela est possible.	Web, Web2, HAProxy-DMZ, Syslog-GVA
Moyenne	Désactiver les services inutiles et maintenir les systèmes à jour.	Toutes les machines

6. Conclusion

En conclusion, l'audit SCA réalisé avec Wazuh permet d'identifier clairement les axes d'amélioration de l'infrastructure. Il complète les tests de détection Wazuh en apportant une vision conformité et durcissement système. Les scores obtenus devront être suivis dans le temps afin de mesurer l'impact des corrections appliquées et de se rapprocher progressivement de l'objectif de conformité fixé à 70 %.

Annexe - Captures SCA Wazuh

Les captures ci-dessous servent de preuves visuelles des scores SCA relevés dans la console Wazuh pour les différents agents supervisés.

Figure 1 - Résultat SCA Wazuh du contrôleur de domaine DC01

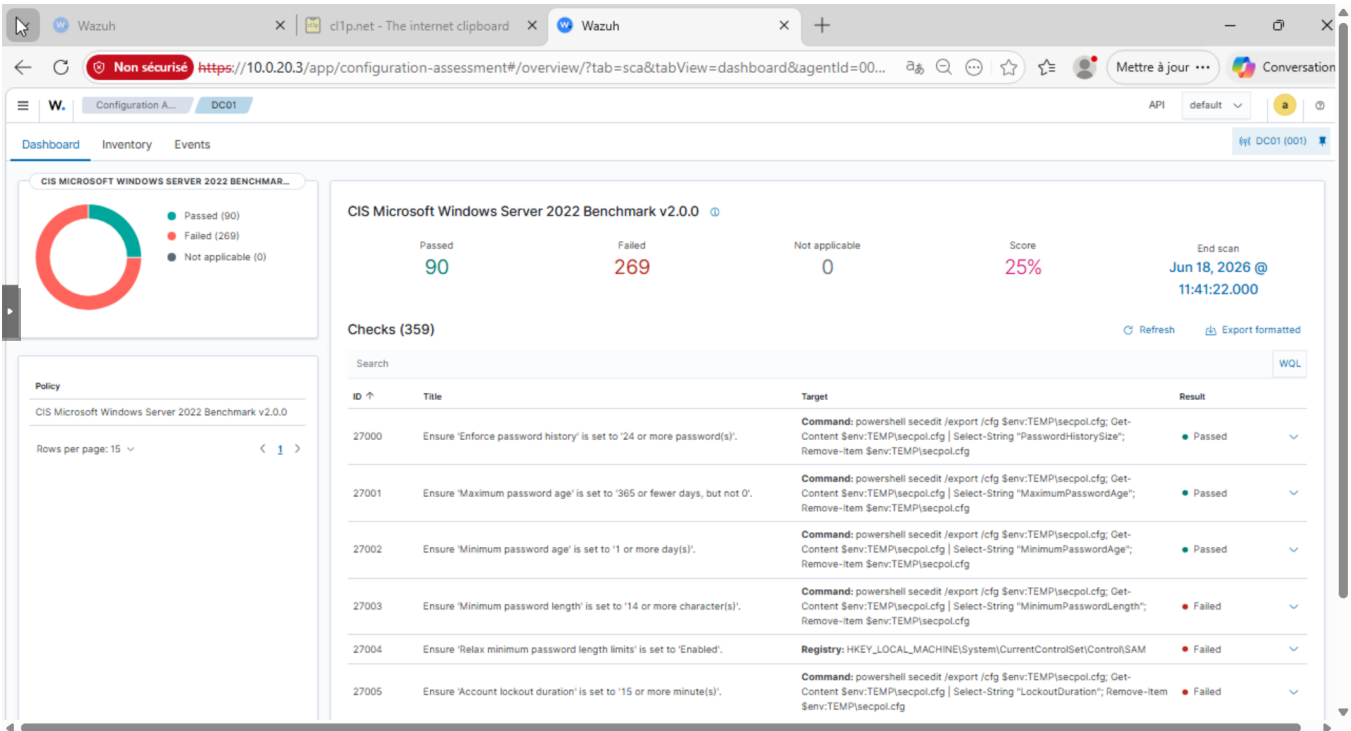


Figure 1 - Résultat SCA Wazuh du contrôleur de domaine DC01 : score de conformité de 25 % selon le benchmark CIS Microsoft Windows Server 2022.

Figure 2 - Résultat SCA Wazuh du contrôleur de domaine DC02

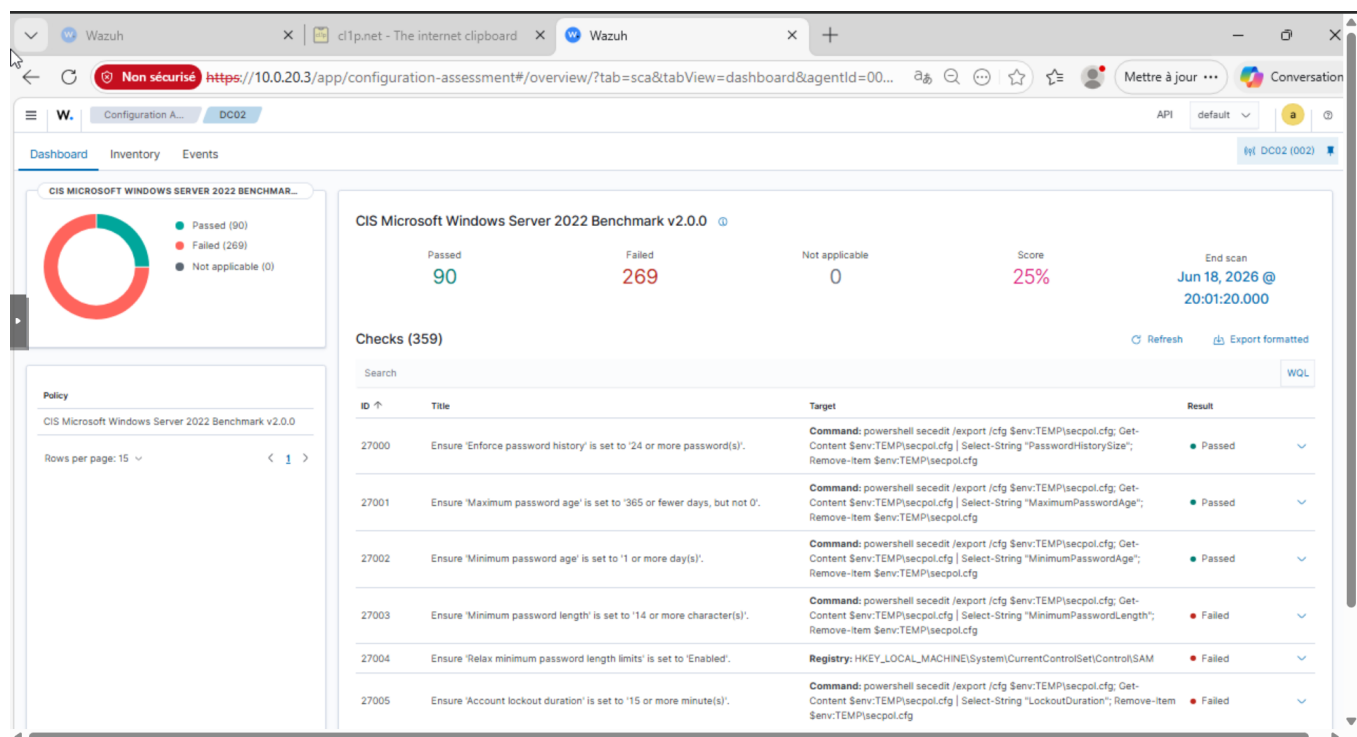


Figure 2 - Résultat SCA Wazuh du contrôleur de domaine DC02 : score de conformité de 25 % selon le benchmark CIS Microsoft Windows Server 2022.

Figure 3 - Résultat SCA Wazuh du serveur Web

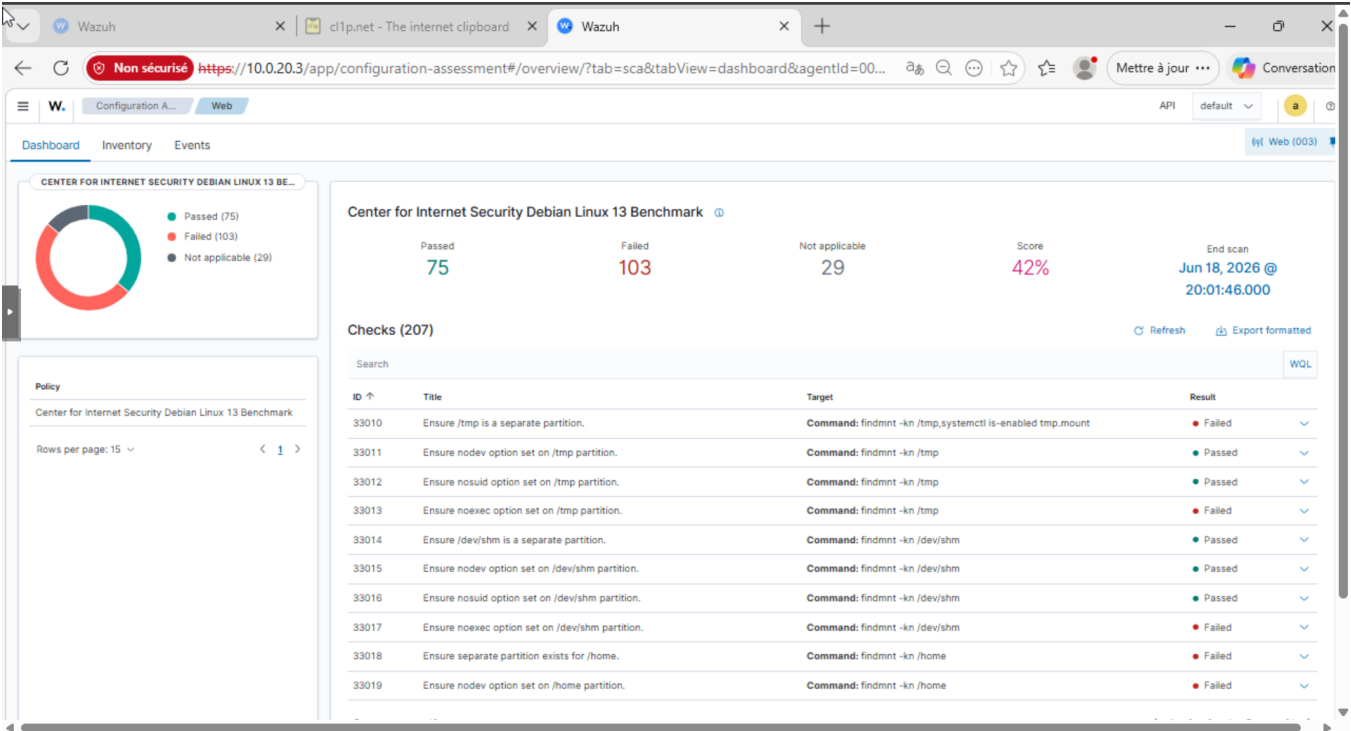


Figure 3 - Résultat SCA Wazuh du serveur Web : score de conformité de 42 % selon le benchmark CIS Debian Linux 13.

Figure 4 - Résultat SCA Wazuh du serveur Web2

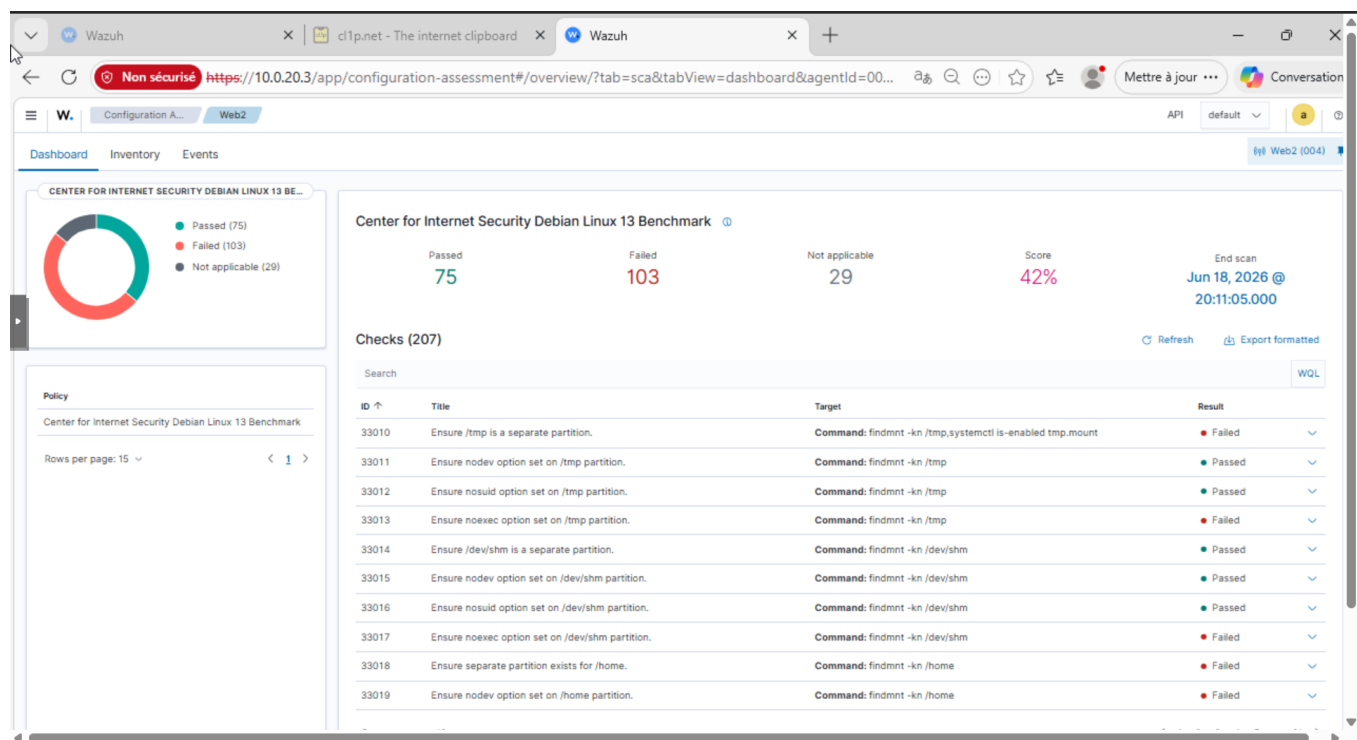


Figure 4 - Résultat SCA Wazuh du serveur Web2 : score de conformité de 42 % selon le benchmark CIS Debian Linux 13.

Figure 5 - Résultat SCA Wazuh du serveur HAProxy-DMZ

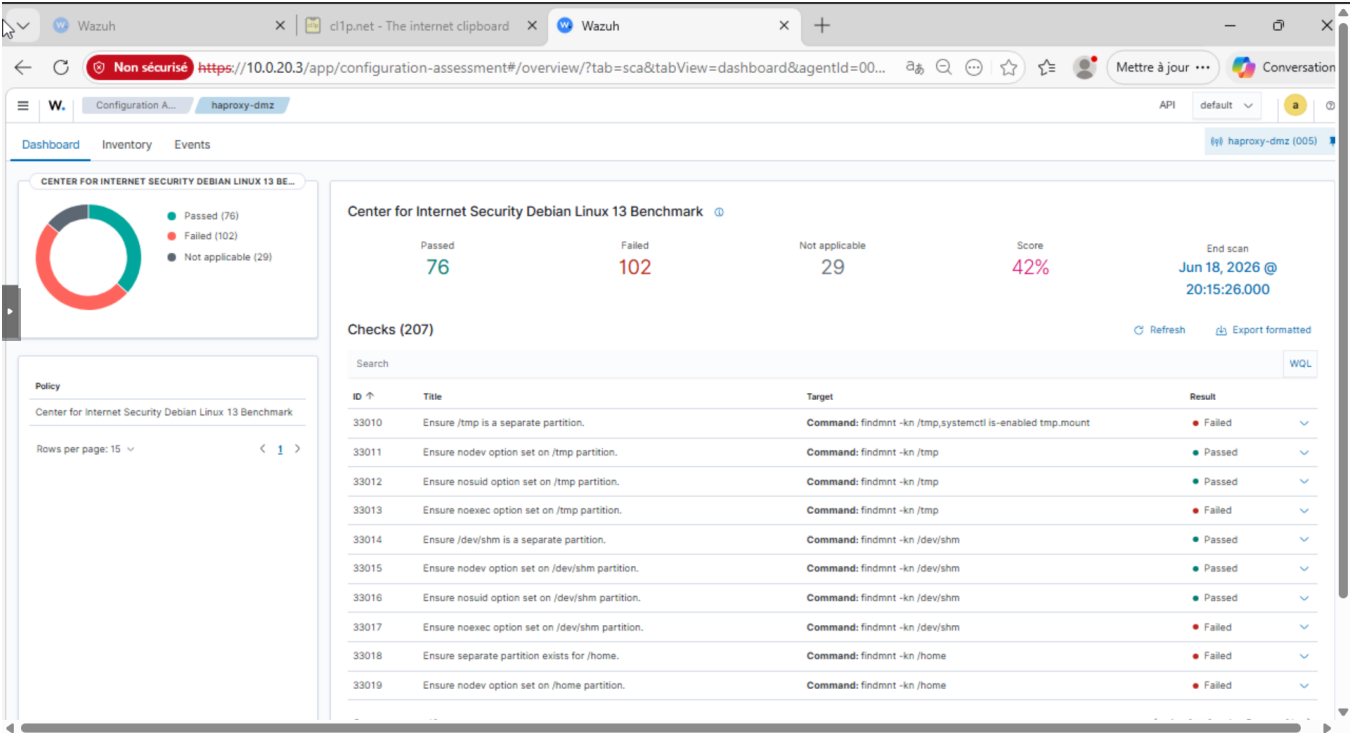


Figure 5 - Résultat SCA Wazuh du serveur HAProxy-DMZ : score de conformité de 42 % selon le benchmark CIS Debian Linux 13.

Figure 6 - Résultat SCA Wazuh du serveur Syslog-GVA

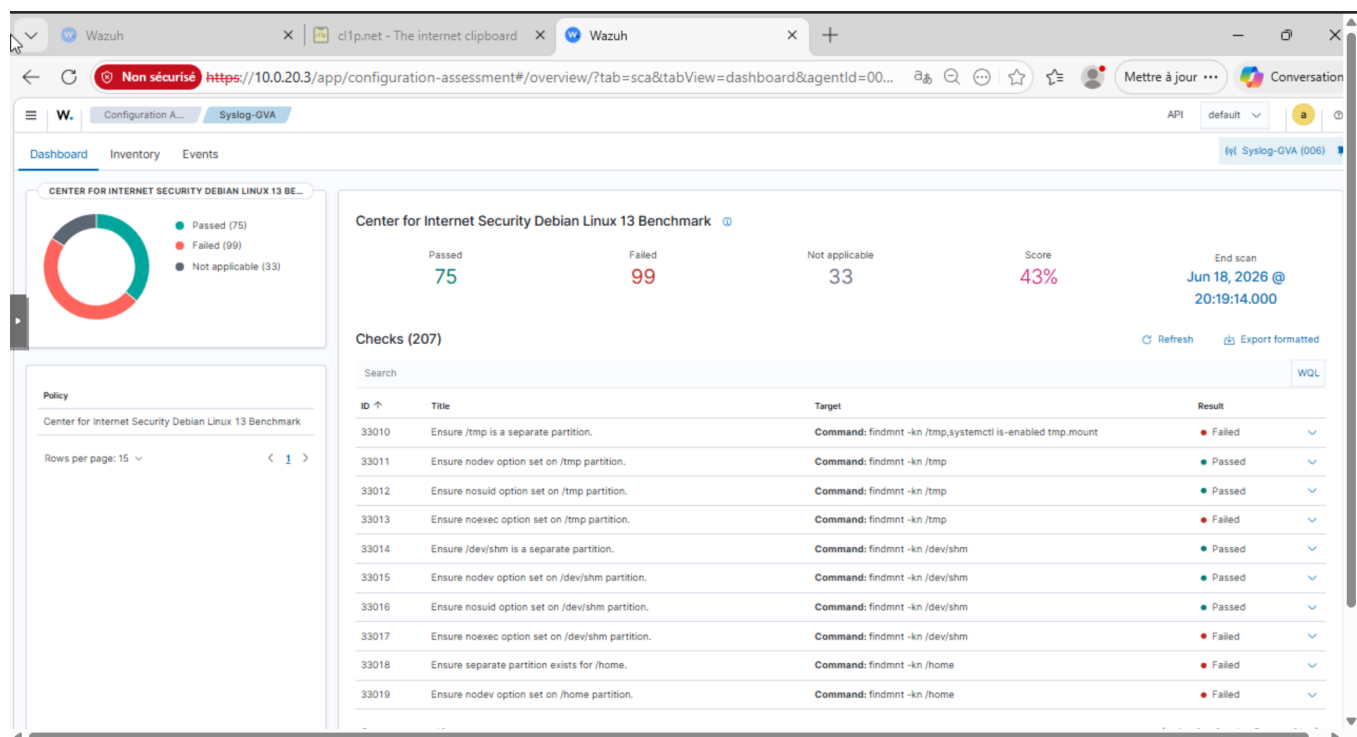


Figure 6 - Résultat SCA Wazuh du serveur Syslog-GVA : score de conformité de 43 % selon le benchmark CIS Debian Linux 13.

Figure 7 - Résultat SCA Wazuh du serveur Veeam

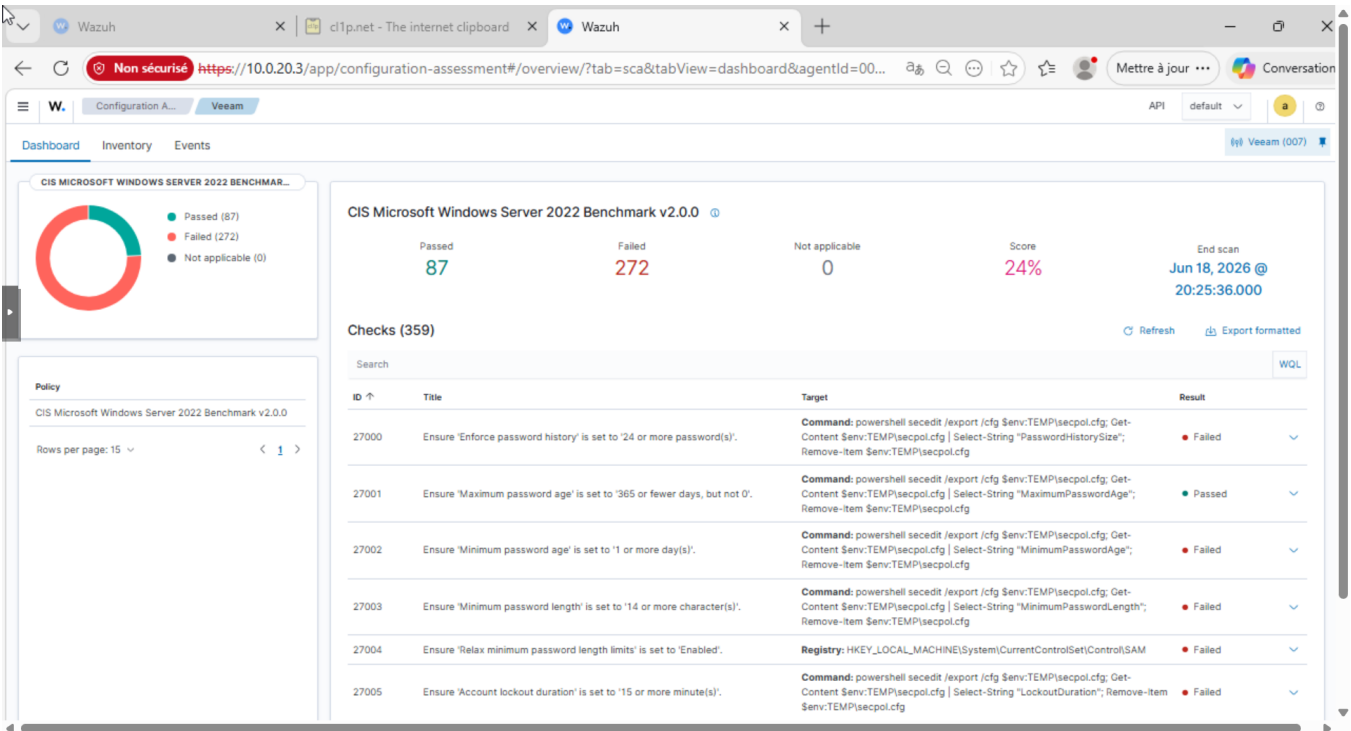


Figure 7 - Résultat SCA Wazuh du serveur Veeam : score de conformité de 24 % selon le benchmark CIS Microsoft Windows Server 2022.